

Catálogo de Controles de Seguridad del Proyecto (OWASP Top 10)

Sistema de Gestión de Pedidos - Leofit Solutions

1. Matriz de Mitigación de Riesgos OWASP Top 10 (2021-2026)

Código OWASP	Categoría de Vulnerabilidad	Control Implementado en Leofit	Componente / Archivo de Implementación
A01:2021	**Broken Access Control** (Pérdida de Control de Acceso)	Middleware de verificación de roles RBAC estricto (`requireRole('ADMIN')`) en rutas mutables de pedidos, stock y usuarios.	`backend/src/middlewares/role.middleware.ts`
A02:2021	**Cryptographic Failures** (Fallas Criptográficas)	Cifrado unidireccional de contraseñas con `bcrypt` (10 rondas de salt). Transmisión 100% cifrada bajo TLS 1.3 (HTTPS) y tokens JWT con firma HMAC-SHA256.	`backend/src/infrastructure/security/`
A03:2021	**Injection** (Inyecciones SQL / Command)	Uso estricto del Patrón Repositorio con consultas parametrizadas `\$1, \$2, ...` en `pg` (evita concatenación directa de strings) y validación de esquemas Zod.	`backend/src/infrastructure/repositories/pg.repositories.ts`
A04:2021	**Insecure	Validación atómica	`backend/src/infrastructure/repositories/pg.rep

1**	Design** (Diseño Inseguro)	de inventario con bloqueos transaccionales `FOR UPDATE` para impedir condiciones de carrera (*race conditions* / *over-selling*).	ositories.ts`
A05:2021	**Security Misconfiguration** (Configuración Errónea)	Cabeceras HTTP endurecidas vía `helmet` (HSTS, No-Sniff, Frameguard, X-XSS-Protection) y desactivación de divulgación de versiones (`X-Powered-By`).	`backend/src/app.ts`
A06:2021	**Vulnerable and Outdated Components**	Análisis automatizado de dependencias mediante `npm audit` y pipelines de CI/CD en GitHub Actions.	`.github/workflows/ci-cd.yml`
A07:2021	**Identification and Auth Failures**	Límite de intentos de autenticación (*Rate Limiting* de 20 intentos cada 15 min), expiración forzada de tokens JWT a 1 hora.	`backend/src/middlewares/rateLimit.middleware.ts`
A08:2021	**Software and Data Integrity Failures**	Integridad de respaldos mediante firmas SHA-256 e inmutabilidad de logs de auditoría de estados.	`database/backup_strategy.sh`
A09:2021	**Security	Registro	`database/schema.sql`

1**	Logging and Monitoring Failures**	estructurado de eventos HTTP mediante `morgan` y tabla de auditoría dedicada `order_status_history` con marcas temporales y usuarios responsables.	
A10:2021	**Server-Side Request Forgery (SSRF)**	Restricción de URLs externas en el catálogo a dominios de confianza validados por esquemas Zod.	`backend/src/infrastructure/validators/schemas.ts`